

GATEWAY / PROCESSOR TAXONOMY AUDIT

PART 3 – FINAL GATEWAY / PROCESSOR TAXONOMY

FAMILY GP-001: AI-ENHANCED API PARAMETER MANIPULATION

A. IDENTITY

Field	Value
Attack ID	GP-001
Attack Family	AI-Enhanced API Parameter Manipulation
Attack Subtypes / Variants	Payment amount manipulation; Prompt injection for parameter changes; Currency manipulation; Merchant ID manipulation; Parameter injection via AI agents
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Payment Initiation (instruction manipulation); Authorization (reduced amount authorized)
Target / Actor	Gateway API endpoints; AI agents with payment capabilities; Merchant checkout flows
Attack Objective	Pay reduced amounts; obtain services for free; extract payment data; evade transaction controls
Technical Control Targeted	API parameter validation; amount/currency verification; AI agent permission boundaries

B. FRAUD UNDERSTANDING

What is the attack?

Attackers manipulate API request parameters to alter payment outcomes. With GenAI, the attack extends to **prompt injection** against AI agents, where natural language instructions manipulate agent decision-making to change financial parameters without direct API tampering.

Tenable Research successfully hijacked an AI agent built in Microsoft Copilot Studio using prompt injection, bypassing identity verification and altering a booking to charge €0 — effectively granting free travel services.Security researchers note: "When AI agents have the ability to move money, prompt injection isn't a curiosity — it's a catastrophic risk vector."

Traditional mechanism:

Before GenAI, attackers manually crafted API requests with altered parameters or intercepted requests in transit. Detection was possible through parameter validation and consistency checks.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Attack vector	Manual API request crafting	Prompt injection against AI agents
Parameter changes	Manual, detectable	Autonomous, context-aware
Scale	Limited by manual effort	Industrial-scale
Detection evasion	Static patterns	Adaptive optimization

Why GenAI is load-bearing:

If GenAI is removed, attackers lose the ability to manipulate AI agents through prompt injection, autonomously discover vulnerable parameter combinations, and adapt parameter changes based on detection feedback. Traditional API manipulation remains but is more detectable.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- Access to gateway API or AI agent workflow
- Understanding of API parameter structure
- (For agent variant) Access to an AI agent's workflow

Attack Flow:

1. Attacker identifies vulnerable API endpoint or AI agent workflow
2. (Agent variant) Injects prompt to manipulate agent reasoning
3. API request submitted with manipulated parameters
4. Gateway processes manipulated request (reduced amount, changed currency, etc.)
5. Transaction authorized at manipulated value
6. Attacker receives goods/services at reduced cost

Gateway/Processor Lifecycle Point: Request intake → API handling → Transaction transformation

Merchant Role: Victim (underpaid for goods/services) or compromised merchant account

Acquirer Role: Processes manipulated transaction; may not detect if parameters appear legitimate

Downstream Payment / Financial Consequence:

- Merchant underpayment
- Free goods/services via €0 transactions
- Transaction limit evasion
- Direct financial loss to merchants

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
API	Amount deviations from merchant baseline	Indicates manipulation	Supervised ML; anomaly detection	Yes
API	Unusual parameter combinations	Parameter injection attempts	Rules; ML classification	No
Transaction	Order value vs. payment amount mismatch	Core signal of manipulation	Rule-based; ML	No
Behavioral	Prompt injection patterns in agent inputs	Agent manipulation	NLP; LLM-based detection	No
Behavioral	Agent reasoning anomalies	Unauthorized parameter changes	Anomaly detection	No
Temporal	Rapid parameter variation testing	Automated manipulation	Velocity rules; anomaly detection	Yes
Network	Similar parameter patterns across merchants	Coordinated manipulation	Graph analytics	Yes – essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Vary manipulation patterns to avoid detection
- Distribute attacks across multiple merchants/IPs
- Use AI agents that appear legitimate in their reasoning
- Inject prompts that mimic legitimate agent instructions
- Combine parameter manipulation with legitimate transactions

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate discount/promotion	Payment amount lower than list price	Blocking valid promotions
Multi-currency transactions	Currency differences from baseline	Flagging legitimate international sales
Legitimate API automation	High-volume API requests	Blocking valid automated workflows
Agentic shopping assistants	AI agents making purchases	Flagging legitimate agent transactions

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Hybrid (Agentic for prompt injection + Algorithmic for parameter variation)
Synthetic Gateway	API endpoint with validation logic; AI agent workflow

Field	Value
Synthetic Merchants	Merchant profiles with transaction baselines
API Requests	Requests with varying parameters (amount, currency, merchant ID)
Transactions	Manipulated transaction records
Transaction Sequences	Normal → manipulation attempt → success/failure
Request Timing	Variable timing patterns
Retry Behavior	Adaptive retries after validation failures
State Transitions	Created → Pending → Authorized (manipulated amount)
Network Relationships	Cross-merchant manipulation patterns
GenAI-Generated Behavior	Prompt injection payloads; adaptive parameter combinations
Attack Labels	Amount manipulation; prompt injection; parameter tampering
Variant Parameters	Manipulation type (amount/currency/MCC); injection technique
Legitimate Counterpart	Valid discounts; multi-currency transactions; legitimate automation
Edge Cases	Partial manipulation; mixed legitimate/fraudulent requests

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
Tenable researchers hijacked AI agent to book €0 travel and leak payment data	Tenable / Ynetnews	Dec 2025	Security research	Verified
Prompt injection is a "catastrophic risk vector" for AI agents with payment capabilities	Payman AI	Nov 2025	Industry analysis	Verified
No-code agentic AI platforms can be exploited for financial fraud via prompt injection	Tenable / SecurityBrief	Dec 2025	Security research	Verified
Indirect prompt injection in PDF invoice metadata tricked AI agent into executing payment	Witness AI	Oct 2025	Security research	Verified

F. PRODUCT MAPPING

Component	Details
Generate	Prompt injection payloads; parameter variation sequences; agent interaction logs
Defend	Parameter validation; anomaly detection; NLP for prompt injection; agent behavior monitoring
Mitigation	Allow (normal); Challenge (step-up verification); Hold (manual review); Block (confirmed manipulation)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-002: AI-ENHANCED WEBHOOK / CALLBACK FORGERY

A. IDENTITY

Field	Value
Attack ID	GP-002
Attack Family	AI-Enhanced Webhook / Callback Forgery
Attack Subtypes / Variants	Stripe webhook signature bypass; PayPal IPN forgery; LLM gateway webhook exploitation; Quota fraud
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Payment Initiation (payment completion signals); Settlement (quota credits)
Target / Actor	Gateway webhook endpoints; LLM gateway systems; Merchant order fulfillment systems
Attack Objective	Credit arbitrary quota; mark orders paid without payment; trigger refunds
Technical Control Targeted	Webhook signature validation; event authenticity verification; quota/credit management

B. FRAUD UNDERSTANDING

What is the attack?

Attackers forge webhook notifications to credit accounts or mark orders as paid without actual payment. GenAI extends this to **LLM gateway vulnerabilities** where webhook signature validation can be bypassed.

CVE-2026-41432 documents a critical vulnerability in New API — an LLM gateway and AI asset management system. The Stripe webhook handler allows an unauthenticated attacker to forge webhook events and credit arbitrary quota without making any payment. When the HMAC secret is empty (the default), any attacker can compute valid webhook signatures, effectively bypassing signature verification entirely.

Traditional mechanism:

Before GenAI, attackers forged webhook payloads to simulate payment success. Detection was possible through signature validation and payload consistency checks.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Attack surface	Generic webhook endpoints	LLM gateway-specific vulnerabilities
Payload generation	Manual payload crafting	Automated, adaptive payload generation
Detection evasion	Static patterns	Learning and adaptation
Impact	Payment status forgery	Unlimited quota fraud at scale

Why GenAI is load-bearing:

If GenAI is removed, the LLM gateway attack surface disappears. The vulnerability exists specifically because the system is an LLM gateway with Stripe integration. The attack targets GenAI infrastructure itself.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- Knowledge of webhook endpoint and payload structure
- Ability to send HTTP requests to the endpoint
- (For LLM gateway variant) Empty or weak webhook secret

Attack Flow:

1. Attacker identifies webhook endpoint (standard or LLM gateway)
2. Crafts forged webhook payload (e.g., `charge.succeeded` event)
3. For LLM gateway: computes HMAC signature with empty key
4. Sends POST request to endpoint
5. Gateway processes forged event without proper validation
6. Account credited; quota granted; order marked paid

Gateway/Processor Lifecycle Point: Response → Callback/webhook processing

Merchant Role: Victim (if webhook handles merchant account operations)

Acquirer Role: Minimal — attack occurs at gateway level

Downstream Payment / Financial Consequence:

- Unauthorized quota credits
- Order fulfillment without payment
- Resource consumption without payment
- Direct financial loss

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
API	Webhook signature validation failures	Signature bypass attempt	Rule-based; anomaly detection	No
API	Webhook requests from unexpected IPs	Potential forgery	Rules; threat intelligence	Yes
Transaction	Quota credits without corresponding payments	Core fraud signal	Rule-based; ML	No

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
Transaction	Order fulfillment without payment	Webhook forgery indicator	Rule-based	No
Behavioral	Webhook payload inconsistencies	Forgery attempt	ML anomaly detection	No
Temporal	Unusual webhook timing	Pattern anomaly	Temporal anomaly detection	Yes
Network	Similar webhook forgery patterns across merchants	Campaign identification	Graph analytics	Yes – essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Rotate IP addresses for webhook requests
- Vary payload patterns to avoid fingerprinting
- Time webhook forgeries during legitimate traffic spikes
- Use compromised legitimate webhook endpoints

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate webhook retry	Multiple webhook deliveries	Flagging valid retries
Legitimate quota grant	Quota credit without immediate payment	Blocking valid quota grants
Legitimate order fulfillment	Order marked paid	Misclassifying valid orders

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Algorithmic
Synthetic Gateway	Webhook receiver with validation logic; LLM gateway with Stripe integration
Synthetic Merchants	Merchant profiles with webhook configurations
API Requests	Forged webhook POST requests
Transactions	Quota credit transactions; order fulfillment records
Transaction Sequences	Webhook forgery → quota credit → resource consumption
State Transitions	Pending → Paid (forged); No payment → Quota credited
GenAI-Generated Behavior	Payload variations to evade detection
Attack Labels	Webhook forgery; quota fraud; order fulfillment fraud
Legitimate Counterpart	Legitimate webhook deliveries; valid quota grants
Edge Cases	Partial forgery; retry scenarios

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
CVE-2026-41432: Stripe webhook signature bypass allows unauthenticated quota fraud	GitHub Advisory / NVD	Apr 2026	Vulnerability	Verified
Empty HMAC secret allows attackers to compute valid webhook signatures	CVE-2026-41432	Apr 2026	Vulnerability	Verified
Vulnerability affects New API LLM gateway before version 0.12.10	VulDB	May 2026	Vulnerability	Verified
CVE-2025-12752: PayPal WordPress plugin allows fake payments via unauthenticated IPN	CVE/NVD	Nov 2025	Vulnerability	Verified

F. PRODUCT MAPPING

Component	Details
-----------	---------

Component	Details
Generate	Forged webhook payloads; signature bypass scenarios; quota credit sequences
Defend	Signature validation; payload consistency checking; quota-payment correlation
Mitigation	Allow (valid); Challenge (verify via callback); Block (invalid/forged)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-003: AI-POWERED CARD TESTING

A. IDENTITY

Field	Value
Attack ID	GP-003
Attack Family	AI-Powered Card Testing
Attack Subtypes / Variants	BIN attacks; Authorization abuse; AI-powered validation platforms; Distributed card testing
Primary Lifecycle Stage	Gateway / Processor (using infrastructure)
Secondary / Cross-stage Stages	Payment Initiation (authorization attempts); Authorization (validation responses)
Target / Actor	Gateway checkout APIs; Payment validation endpoints
Attack Objective	Identify active cards with available funds for exploitation or sale
Technical Control Targeted	API rate limiting; Velocity rules; Fraud detection at checkout

B. FRAUD UNDERSTANDING

What is the attack?

Attackers submit small-value authorization requests via gateway APIs to validate stolen card numbers at scale. GenAI enables **AI-powered platforms** that automate mass card validation with sophisticated APIs.

Brazilian cybercriminals created "E-Fraud" — an AI-powered platform offering automated APIs for mass card validation. The platform uses generative AI to automate checking of illegally obtained card numbers and functions as a sophisticated criminal operation center.

Traditional mechanism:

Before GenAI, attackers used scripted API requests to test card numbers. Detection was possible through velocity rules and pattern analysis.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Scale	Hundreds of tests	Industrial-scale (1M+ transactions)
Automation	Scripted	AI-powered platforms with APIs
Detection evasion	Static patterns	Adaptive, learning patterns
Accessibility	Technical skill required	Platform-based; low barrier

Why GenAI is load-bearing:

If GenAI is removed, attackers lose the ability to operate at industrial scale (1M+ transactions per merchant), adapt testing patterns based on detection feedback, and use AI-powered platforms with sophisticated APIs. One in four blocked card testing attacks operate at the 1M+ transaction scale — a scale only achievable with AI automation.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- Access to gateway API (public checkout endpoints)
- List of stolen card numbers
- (For platform variant) Access to AI-powered validation platform

Attack Flow:

1. Attacker obtains list of stolen card numbers
2. Uses AI-powered platform or script to submit small-value authorization requests

- 3. Gateway attempts authorization for each card
- 4. Success/failure responses indicate card validity
- 5. Valid cards flagged for exploitation or sale

Gateway/Processor Lifecycle Point: Request intake → API handling → Authorization interaction

Merchant Role: Victim – legitimate merchant's checkout API is abused

Acquirer Role: Processes authorization requests; may detect if monitoring is effective

Downstream Payment / Financial Consequence:

- Financial loss from chargebacks
- System pollution with failed orders
- Merchant reputation damage
- Valid cards sold on fraud marketplaces

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
API	High API request rate from single source	Automated card testing	Velocity rules; anomaly detection	No
Transaction	Small, consistent transaction amounts	Card testing signature	ML classification	No
Transaction	High decline rate	Invalid card testing	Rules; ML	No
Transaction	Multiple cards from same BIN range	Organized testing	BIN analysis	Yes
Device	Same device fingerprint across multiple cards	Automated testing	Device fingerprinting	Yes
Behavioral	Unnatural checkout patterns	Bot behavior	Behavioral analytics	No
Network	Card testing patterns across merchants	Campaign identification	Graph analytics	Yes – essential
Temporal	Rapid checkout attempts	Automated testing	Velocity rules; anomaly detection	Yes

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Distribute card testing across multiple IPs/proxies
- Vary transaction amounts to avoid pattern detection
- Use legitimate-looking customer information
- Mimic human checkout behavior (delays, mouse movements)
- Rotate card BIN ranges to avoid BIN-based detection

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate high-volume merchant	Many transactions	Blocking successful merchants
Customer trying multiple cards	Multiple payment attempts	Flagging legitimate users
Flash sale traffic spike	High transaction volume	Blocking legitimate sales
Subscription billing	Repeated small transactions	Flagging legitimate subscriptions

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Algorithmic
Synthetic Gateway	Checkout API with velocity rules
Synthetic Merchants	Merchant profiles with transaction baselines
API Requests	Card testing authorization requests
Transactions	Small-value authorization attempts

Field	Value
Transaction Sequences	Card testing sequences with success/failure patterns
Request Timing	High-velocity patterns
State Transitions	Created → Pending → Declined/Authorized
Network Relationships	Card testing campaigns; BIN clusters
Error Patterns	High decline rates; specific decline codes
GenAI-Generated Behavior	Transaction pattern variation to evade detection
Attack Labels	Card testing; BIN attack; authorization abuse
Legitimate Counterpart	Legitimate high-volume transactions; multiple payment attempts
Edge Cases	Mixed legitimate/fraudulent cards; partial success

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
E-Fraud platform uses generative AI to automate card validation	CISO Advisor	Jan 2026	Security research	Verified
Platform operates as criminal hub with sophisticated AI-powered interface	Canaltech	Jan 2026	Security research	Verified
E-Fraud offers APIs for mass validation of stolen card numbers	Swarmy researchers	Jan 2026	Security research	Verified
One in four blocked card testing attacks operate at 1M+ transaction scale	Stripe/Industry	2025	Industry data	Verified

F. PRODUCT MAPPING

Component	Details
Generate	Card testing sequences; BIN patterns; distributed IP/device patterns
Defend	Velocity rules; ML classification; anomaly detection; graph analytics
Mitigation	Allow (normal); Rate-limit; Challenge (CAPTCHA); Block (confirmed testing)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-004: AGENTIC PAYMENT PROTOCOL EXPLOITATION

A. IDENTITY

Field	Value
Attack ID	GP-004
Attack Family	Agentic Payment Protocol Exploitation
Attack Subtypes / Variants	x402 protocol attacks; AP2 protocol exploitation; Replay/idempotency attacks; Header/proxy confusion; Delegation chain attacks; Prompt injection in agentic payments
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Payment Initiation (payment proofs); Settlement (blockchain state)
Target / Actor	Agentic payment protocol infrastructure; AI agents with payment capabilities
Attack Objective	Reuse payment proofs; manipulate protocol messages; execute unauthorized payments; extract sensitive data
Technical Control Targeted	Protocol authorization; Binding; Replay protection; Cross-layer security

B. FRAUD UNDERSTANDING

What is the attack?

Attackers exploit vulnerabilities in agentic payment protocols (x402, AP2) through protocol-level attacks, prompt injection, and cross-layer exploitation. The x402 protocol revives HTTP 402 ("Payment Required") as a web-native micro-payment handshake for AI agents.

Academic research has identified five concrete attacks on the x402 protocol, including replay/idempotency attacks where one payment can be reused for many grants.

Traditional mechanism:

This is a **new attack surface** with no traditional equivalent. Agentic payment protocols exist specifically to enable AI agent transactions.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Attack surface	None	Agentic payment protocols (x402, AP2)
Attack vectors	N/A	Protocol manipulation; prompt injection; replay
Scale	N/A	Autonomous, large-scale protocol exploitation

Why GenAI is load-bearing:

If GenAI is removed, the attack surface disappears entirely. Agentic payment protocols exist specifically to enable AI agent transactions. The attacks target the AI agent infrastructure itself – not traditional payment systems.

HARD GenAI Removal Test result: PASS

Prerequisites:

- Access to agentic payment protocol
- Ability to inject prompts or manipulate protocol messages
- Understanding of protocol state machine

Attack Flow:

1. Attacker identifies vulnerable agentic payment protocol (x402, AP2)
2. Exploits protocol weakness (replay, header confusion, delegation chain)
3. Payment proof reused for multiple grants
4. Protocol state manipulated
5. Unauthorized payments executed; data exposed

Gateway/Processor Lifecycle Point: Protocol processing → Validation → Routing → Settlement

Merchant Role: Victim (merchant in agentic commerce ecosystem)

Acquirer Role: Processes agentic protocol transactions

Downstream Payment / Financial Consequence:

- Multiple grants from single payment
- Unauthorized payments
- Cross-account data exposure
- Protocol-level fraud at scale

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
API	Protocol message anomalies	Protocol attack	Protocol validation	No
Behavioral	Prompt injection patterns	Agent manipulation	NLP; LLM-based detection	No
Transaction	Reused payment proofs	Replay attack	Idempotency tracking	No
Transaction	Multiple grants from single payment	Core fraud signal	Rule-based; ML	No
Behavioral	Agent reasoning anomalies	Hijacking detection	Anomaly detection	No
State	Protocol state inconsistencies	State manipulation	State consistency checking	No
Network	Similar attack patterns across protocols	Coordinated attack	Graph analytics	Yes – essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Use varied prompt injection techniques
- Exploit asynchronous blockchain state updates
- Construct sub-delegation chains exceeding max_chain_length
- Vary attack patterns to avoid fingerprinting

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate idempotent retry	Same payment proof retried	Flagging valid retries
Legitimate agent shopping	Agent payment interactions	Flagging legitimate agent behavior
Protocol retry	Multiple protocol messages	Flagging valid retries

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Agentic
Synthetic Gateway	x402/AP2 protocol endpoint with LLM integration
Synthetic Merchants	Agentic commerce merchants
API Requests	x402/AP2 protocol messages; payment requests
Transactions	Payment records; grant records; blockchain settlement
Transaction Sequences	Protocol interaction → payment → settlement
Protocol Context	HTTP 402 status; delegation grants; blockchain state
Network Relationships	Protocol attack patterns
GenAI-Generated Behavior	Prompt injection payloads; protocol messages
Attack Labels	Prompt injection; protocol exploitation; replay; data exposure
Variant Parameters	Protocol type; attack technique; injection method
Legitimate Counterpart	Legitimate agentic commerce transactions
Edge Cases	Partial protocol exploitation; mixed attacks

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
Five concrete attacks identified on x402 agentic payment protocol	arXiv	2025	Academic research	Verified
x402 protocol revives HTTP 402 as web-native micro-payment handshake	arXiv	2025	Academic research	Verified
AP2 protocol introduced by Google, PayPal and others for AI agent payments	arXiv	2025	Academic research	Verified
Security flaws found in Coinbase and 14 x402 payment facilitators	USENIX Security Symposium	Aug 2026	Academic research	Verified
Agentic commerce platforms already handle real money	arXiv	2025-2026	Academic research	Verified

F. PRODUCT MAPPING

Component	Details
Generate	Agentic protocol messages; prompt injection payloads; protocol state transitions
Defend	Protocol validation; idempotency tracking; NLP; anomaly detection; graph analytics
Mitigation	Allow (normal); Challenge (verify agent); Block (confirmed exploit)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-005: AI AGENT ROUTING MANIPULATION

A. IDENTITY

Field	Value
Attack ID	GP-005

Field	Value
Attack Family	AI Agent Routing Manipulation
Attack Subtypes / Variants	Payment redirection via AI agents; Processor selection manipulation; Malicious agent routing
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Payment Initiation (routing decisions); Authorization (processor selection)
Target / Actor	AI agents with payment routing capabilities; Gateway routing engine
Attack Objective	Redirect payments; evade fraud controls; access cheaper processing
Technical Control Targeted	Routing logic; Processor selection; AI agent decision-making

B. FRAUD UNDERSTANDING

What is the attack?

Attackers manipulate AI agents to route payments to malicious destinations or processors with weaker controls. Microsoft Research found that AI shopping agents repeatedly fell prey to scams, with some models redirecting all payments to malicious agents.

Traditional mechanism:

Before GenAI, attackers manipulated transaction attributes to influence routing decisions. Detection was possible through routing pattern analysis.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Attack vector	Transaction attribute manipulation	AI agent manipulation
Routing decisions	Rule-based	Agent reasoning-based
Detection evasion	Static patterns	Adaptive, learning
Scale	Manual	Autonomous

Why GenAI is load-bearing:

If GenAI is removed, the attack surface (AI agent routing manipulation) disappears. The attack targets AI agent decision-making specifically. Microsoft Research demonstrated that GPT-4o and open-source variants were highly vulnerable – all payments were successfully redirected to malicious agents.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- Ability to interact with/manipulate AI agents
- Understanding of routing logic
- (For agent variant) Access to AI agent workflow

Attack Flow:

1. Attacker identifies AI agent with payment routing capabilities
2. Manipulates agent via prompt injection or malicious context
3. Agent routes payment to malicious destination
4. Payment processed through weak controls
5. Funds redirected to attacker

Gateway/Processor Lifecycle Point: Routing → Processor selection

Merchant Role: Victim (payments redirected from legitimate merchant)

Acquirer Role: May be the processor being evaded

Downstream Payment / Financial Consequence:

- Payments redirected to attackers
- Fraud evades detection
- Regulatory violations

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
-----------------	-------------------	----------------	------------------	--------------------------

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
Routing	Unusual routing patterns	Potential manipulation	Anomaly detection	Yes
Processor	Unusual processor selection	Routing evasion	Rules; ML	Yes
Behavioral	Prompt injection patterns in agent inputs	Agent manipulation	NLP; LLM-based detection	No
Transaction	Payments to unexpected destinations	Redirection indicator	ML anomaly detection	Yes
Network	Similar routing patterns across agents	Coordinated manipulation	Graph analytics	Yes — essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Mimic legitimate routing optimization patterns
- Use AI agents that appear legitimate in reasoning
- Vary routing destinations to avoid pattern detection
- Combine with legitimate transactions

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate processor change	Different routing destination	Flagging valid processor changes
Dynamic routing optimization	Routing changes based on performance	Misclassifying legitimate optimization
Multi-acquirer setup	Multiple routing destinations	Flagging legitimate multi-acquirer setup

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Hybrid (Agentic for AI agent manipulation + Algorithmic for routing)
Synthetic Gateway	Routing engine with processor selection
Synthetic Merchants	Merchant profiles with routing preferences
API Requests	Payment requests with routing context
Transactions	Transaction records with routing information
Transaction Sequences	Normal routing → manipulated routing → fraud
Routing Context	Routing decisions; processor selection
Network Relationships	Routing patterns across agents
GenAI-Generated Behavior	Routing manipulation prompts; pattern variation
Attack Labels	Routing manipulation; processor evasion; agent hijacking
Legitimate Counterpart	Legitimate routing optimization; multi-acquirer routing
Edge Cases	Partial manipulation; mixed routing

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
AI shopping agents repeatedly fell prey to scams; all payments redirected to malicious agents	Microsoft Research	2025	Academic research	Verified
GPT-4o and open-source variants were highly vulnerable	Microsoft Research	2025	Academic research	Verified
Prompt injection techniques directed payments to manipulative agents	Microsoft Research	2025	Academic research	Verified

F. PRODUCT MAPPING

Component	Details
Generate	Routing manipulation prompts; malicious routing destinations; agent decision logs
Defend	Routing anomaly detection; graph analytics; NLP; agent behavior monitoring

Component	Details
Mitigation	Allow (normal); Challenge (verify routing); Hold (manual review); Block (confirmed manipulation)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-006: AGENT HIJACKING FOR TOKEN ABUSE

A. IDENTITY

Field	Value
Attack ID	GP-006
Attack Family	Agent Hijacking for Token Abuse
Attack Subtypes / Variants	AI assistant credential theft; Stored payment token abuse; Agent hijacking via prompt injection; Malicious website poisoning
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Authentication (credential storage); Payment Initiation (token usage)
Target / Actor	AI assistants with stored payment credentials; Tokenization services
Attack Objective	Use stored payment credentials for unauthorized transactions
Technical Control Targeted	Token access control; Authorization checks; Payment credential storage

B. FRAUD UNDERSTANDING

What is the attack?

Attackers hijack AI assistants to abuse stored payment credentials and tokens, executing unauthorized transactions. Attackers now use agent hijacking tactics to compromise legitimate AI assistants and abuse stored payment credentials. An AI agent with legitimate payment credentials executing a transaction produces logs that look identical to normal operations – there is no anomalous login.

Zscaler found attackers using poisoned search results and hidden web prompts to trick AI agents into sending crypto payments. Researchers identified a 32% increase in indirect command-injection attacks between November 2025 and February 2026.

Traditional mechanism:

Before GenAI, token abuse required exploiting token endpoints directly. Detection was possible through access control monitoring.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Attack vector	Token endpoint exploitation	Agent hijacking
Detection evasion	Anomalous token access	Normal-looking agent transactions
Scale	Limited	Autonomous, large-scale
Attack surface	Token APIs	AI assistants with stored credentials

Why GenAI is load-bearing:

If GenAI is removed, the attack surface (AI assistants with stored credentials) disappears. Agent hijacking targets GenAI infrastructure specifically. The agent itself becomes the compromised endpoint.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- Access to AI assistant (via prompt injection, malicious websites)
- Stored payment credentials in the agent
- Ability to execute transactions through the agent

Attack Flow:

1. Attacker identifies AI assistant with stored payment credentials
2. Uses prompt injection or poisoned search results to hijack agent
3. Agent executes transaction using stored credentials

- 4. Transaction appears legitimate (agent is authorized)
- 5. Unauthorized charges to victim; funds stolen

Gateway/Processor Lifecycle Point: Tokenization/payment data → API handling

Merchant Role: Victim (merchant's tokenization integration is exploited)

Acquirer Role: Processes fraudulent token-based transactions

Downstream Payment / Financial Consequence:

- Unauthorized charges to victim customers
- Financial loss to victims
- Reputational damage

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
Token	Unauthorized token retrieval attempts	Token abuse	Rule-based; anomaly detection	No
Token	Tokens used from unexpected contexts	Hijacking indicator	Contextual validation	No
Behavioral	Agent reasoning anomalies	Hijacking detection	Anomaly detection; NLP	No
Transaction	Unauthorized token-based transactions	Core fraud signal	ML anomaly detection	Yes
Session	Agent session anomalies	Potential hijacking	Session anomaly detection	No
Network	Similar hijacking patterns across agents	Coordinated attack	Graph analytics	Yes — essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Use hijacked agents that appear legitimate
- Execute transactions that match user patterns
- Vary hijacking techniques to avoid detection
- Use malicious websites that appear legitimate

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate token usage	Token used for payment	Flagging valid token usage
User with multiple devices	Tokens used from different contexts	Misclassifying legitimate multi-device usage
Agentic shopping	Agent using stored credentials	Flagging legitimate agent transactions

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Hybrid (Agentic for agent hijacking + Algorithmic for token usage)
Synthetic Gateway	Tokenization service with access controls
Synthetic Merchants	Merchant profiles with tokenized payments
API Requests	Token usage requests; payment requests
Transactions	Token-based transaction records
Transaction Sequences	Normal token usage → hijacking → unauthorized transaction
Session Context	Agent sessions with hijacking indicators
Network Relationships	Hijacking patterns across agents
GenAI-Generated Behavior	Hijacking prompts; transaction patterns
Attack Labels	Agent hijacking; token abuse; credential theft
Legitimate Counterpart	Legitimate token usage; agentic shopping
Edge Cases	Partial hijacking; mixed legitimate/fraudulent

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
Agent hijacking used to compromise AI assistants and abuse stored payment credentials	Akamai	2026	Security research	Verified
Zscaler found attackers using poisoned search results to trick AI agents into sending crypto payments	Zscaler	2025-2026	Security research	Verified
32% increase in indirect command-injection attacks (Nov 2025-Feb 2026)	Security research	2026	Industry data	Verified
Tokenization evolving into defense against AI-agent fraud	PYMNTS	2025	Industry analysis	Verified

F. PRODUCT MAPPING

Component	Details
Generate	Agent hijacking prompts; token usage sequences; agent interaction logs
Defend	Token context validation; agent behavior monitoring; NLP; anomaly detection
Mitigation	Allow (normal); Challenge (verify agent); Block (confirmed hijacking)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

FAMILY GP-007: AI AGENT VELOCITY EVASION

A. IDENTITY

Field	Value
Attack ID	GP-007
Attack Family	AI Agent Velocity Evasion
Attack Subtypes / Variants	Rapid agent shopping; High-velocity transaction bursts; Distributed AI agent fraud
Primary Lifecycle Stage	Gateway / Processor
Secondary / Cross-stage Stages	Payment Initiation (transaction execution); Authorization (real-time decisions)
Target / Actor	Gateway velocity controls; Fraud detection systems
Attack Objective	Execute fraudulent transactions faster than detection systems can flag them
Technical Control Targeted	Velocity rules; Rate limiting; Anomaly detection

B. FRAUD UNDERSTANDING

What is the attack?

AI agents execute transactions at speeds that break traditional velocity checks, evading detection by appearing as legitimate high-velocity activity. Average bot purchase completes in 1.9 seconds – 50× faster than human checkout, triggering false-decline rules. Velocity checks misread rapid agent shopping as card testing.

Mastercard warns that the gap between transaction speed and authentication could open the door to AI-powered fraud.

Traditional mechanism:

Before GenAI, attackers used distributed transactions to stay below velocity thresholds. Detection was possible through velocity rules.

GenAI transformation:

Dimension	Pre-GenAI	GenAI-Transformed
Speed	Human-scale	Millisecond-scale (1.9s per transaction)
Scale	Distributed manual	Autonomous agent networks
Detection evasion	Static patterns	Adaptive optimization
False-positive risk	Low	High (velocity checks misread as card testing)

Why GenAI is load-bearing:

If GenAI is removed, attackers lose the ability to operate at millisecond transaction speeds, autonomously distribute transactions across agent networks, and adapt velocity patterns based on detection feedback. Traditional velocity controls were designed for human transaction speeds.

HARD GenAI Removal Test result: PARTIAL

Prerequisites:

- AI agent infrastructure
- Access to payment APIs
- Ability to execute high-velocity transactions

Attack Flow:

1. Attacker deploys AI agents across payment infrastructure
2. Agents execute transactions at millisecond speeds
3. Velocity checks misread as legitimate high-velocity activity
4. Fraudulent transactions completed before detection
5. Agents adapt patterns based on detection feedback

Gateway/Processor Lifecycle Point: Request intake → Monitoring

Merchant Role: May be victim or attacker

Acquirer Role: May detect if portfolio-level monitoring is effective

Downstream Payment / Financial Consequence:

- Fraudulent transactions processed without detection
- Cumulative losses
- False declines for legitimate high-volume merchants

C. DETECTION INTELLIGENCE

Signal Category	Observable Signal	Why It Matters	Detection Method	Cross-Merchant Required?
API	Superhuman request rates	AI agent detection	Velocity rules; anomaly detection	No
Transaction	Checkout completion time anomaly	Bot detection	Temporal anomaly detection	No
Behavioral	Bot-like transaction patterns	Automation detection	Behavioral analytics	No
Temporal	Consistent high-velocity patterns	AI agent signature	Pattern analysis	Yes
Network	Coordinated velocity patterns	Campaign identification	Graph analytics	Yes — essential

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Vary transaction timing to appear more human-like
- Distribute transactions across multiple agents
- Mimic legitimate high-volume merchant patterns
- Use AI agents with human-like delays

Legitimate Behavior That Could Look Similar:

Legitimate Scenario	Why It Looks Similar	False-Positive Risk
Legitimate high-volume merchant	Many transactions	Blocking successful merchants
Flash sale traffic	High transaction velocity	Blocking legitimate sales
API automation	Rapid transactions	Flagging legitimate automation
Agentic shopping	AI agent transactions	Misclassifying legitimate AI agents

D. SIMULATION INTELLIGENCE

Field	Value
Simulation Type	Hybrid (Agentic for AI agents + Algorithmic for velocity patterns)
Synthetic Gateway	Gateway with velocity controls

Field	Value
Synthetic Merchants	Merchant profiles with velocity baselines
API Requests	High-velocity transaction requests
Transactions	Rapid-fire transaction sequences
Transaction Sequences	High-velocity transaction bursts
Request Timing	Millisecond-scale timing
Network Relationships	Coordinated velocity patterns
GenAI-Generated Behavior	Velocity pattern variation
Attack Labels	Velocity evasion; AI agent fraud; automated abuse
Legitimate Counterpart	Legitimate high-volume merchants; flash sales
Edge Cases	Mixed AI/human transactions

E. EVIDENCE

Claim	Source	Date	Evidence Type	Confidence
Average bot purchase completes in 1.9 seconds — 50× faster than human checkout	Industry	2025	Industry data	Verified
Velocity checks misread rapid agent shopping as card testing	Industry	2025	Industry analysis	Verified
Mastercard warns gap between transaction speed and authentication enables AI-powered fraud	Mastercard	2025	Payment network	Verified
Criminals building reusable infrastructure including AI tooling	Visa	2025	Payment network	Verified

F. PRODUCT MAPPING

Component	Details
Generate	High-velocity transaction sequences; AI agent coordination logs; velocity patterns
Defend	Velocity rules; anomaly detection; behavioral analytics; graph analytics
Mitigation	Allow (normal); Rate-limit; Challenge (step-up verification); Block (confirmed automation)
Evaluation	Precision; Recall; F1; AUC; False Positive Rate

PART 4 – FINAL COVERAGE AUDIT

Gateway/Processor Attack Surface	Considered?	Covered By	Separate Family?	Reason
Payment API abuse	✓	GP-001, GP-003, GP-005, GP-007	No	Covered across multiple families
Unauthorized API use	✓	GP-001, GP-003	No	Covered by API parameter manipulation and card testing
Merchant integration abuse	✓	GP-001, GP-006	No	Integration is the attack vector
API parameter manipulation	✓	GP-001	Yes	Distinct family
Automated transaction abuse	✓	GP-003, GP-007	No	Covered by card testing and velocity evasion
Transaction message manipulation	✓	DROPPED	No	GP-004 dropped — no GenAI evidence
Transaction substitution	✓	DROPPED	No	No GenAI evidence
Transaction identifier manipulation	✓	DROPPED	No	No GenAI evidence
Transaction state manipulation	✓	GP-002	No	Webhook forgery variant
Response/callback manipulation	✓	GP-002	Yes	Distinct family
Webhook abuse	✓	GP-002	Yes	Distinct family
Replay attacks	✓	GP-004	No	Variant of agentic protocol exploitation

Gateway/Processor Attack Surface	Considered?	Covered By	Separate Family?	Reason
Duplicate transaction submission	✓	GP-004	No	Variant of agentic protocol exploitation
Idempotency abuse	✓	GP-004	No	Variant of agentic protocol exploitation
Transaction duplication	✓	GP-004	No	Variant of agentic protocol exploitation
Routing manipulation	✓	GP-005	Yes	Distinct family
Processor selection manipulation	✓	GP-005	No	Variant of routing manipulation
Failover abuse	✓	THEORETICAL	No	Insufficient evidence
Token abuse	✓	GP-006	Yes	Distinct family
Token substitution	✓	GP-006	No	Variant of token abuse
Payment-data misuse	✓	GP-006	No	Variant of token abuse
Processor-side monitoring evasion	✓	GP-007	No	Covered by velocity evasion
Velocity-control evasion	✓	GP-007	Yes	Distinct family
Rate-limit evasion	✓	GP-007	No	Covered by velocity evasion
Distributed transaction behavior	✓	GP-003, GP-007	No	Covered by card testing and velocity evasion
Gateway compromise	✓	DROPPED	No	No GenAI evidence
Processor compromise	✓	DROPPED	No	No GenAI evidence (FASTCash dropped)
Configuration manipulation	✓	DROPPED	No	Insufficient evidence
Administrative abuse	✓	DROPPED	No	Insufficient evidence
API credential compromise	✓	MOVED → Authentication	No	Credential theft is Authentication-stage
Coordinated transaction abuse	✓	GP-003, GP-007	No	Covered across families
Adaptive GenAI API behavior	✓	GP-001, GP-003	No	GenAI capability across families
Agentic transaction interaction	✓	GP-004	Yes	Distinct family
Prompt injection in payments	✓	GP-001, GP-004, GP-005, GP-006	No	GenAI capability across families
LLM gateway vulnerabilities	✓	GP-002	Yes	Distinct family

Excluded Candidates – Detailed Rationale

Candidate	Decision	Rationale
GP-004: ISO 8583 Manipulation	DROPPED	FASTCash malware shows no GenAI evidence
GP-009: API Key Theft	MOVED → Authentication	Credential theft is fundamentally an authentication-stage attack
GP-011: Configuration Manipulation	DROPPED	Insufficient evidence of GenAI transformation
Transaction substitution	DROPPED	No GenAI evidence
Transaction identifier manipulation	DROPPED	No GenAI evidence
Gateway compromise	DROPPED	No GenAI evidence
Processor compromise	DROPPED	No GenAI evidence (FASTCash dropped)
Administrative abuse	DROPPED	Insufficient evidence
Failover abuse	THEORETICAL	Plausible but insufficient evidence

PART 5 – FINAL SUMMARY

Table 1 – FINAL GATEWAY / PROCESSOR ATTACK TAXONOMY

ID	Attack Family	Variants	GenAI Classification	Simulation Type	Primary Stage	Technical Control	Reason for Distinctness
GP-001	AI-Enhanced API Parameter Manipulation	Payment amount manipulation; Prompt injection; Currency manipulation	PARTIAL	Hybrid	Gateway/Processor	API parameter validation	GenAI enables prompt injection against AI agents; qualitatively new attack vector
GP-002	AI-Enhanced Webhook/Callback Forgery	Stripe webhook bypass; PayPal IPN forgery; LLM gateway exploitation	PARTIAL	Algorithmic	Gateway/Processor	Webhook signature validation	LLM gateway vulnerability CVE-2026-41432 demonstrates GenAI-specific attack
GP-003	AI-Powered Card Testing	BIN attacks; Authorization abuse; AI validation platforms	PARTIAL	Algorithmic	Gateway/Processor	API rate limiting; Velocity rules	AI-powered platforms enable industrial-scale validation
GP-004	Agentic Payment Protocol Exploitation	x402 protocol attacks; AP2 exploitation; Replay/idempotency attacks	PASS	Agentic	Gateway/Processor	Protocol authorization; Binding; Replay protection	New attack surface created by GenAI
GP-005	AI Agent Routing Manipulation	Payment redirection; Processor selection evasion; Malicious agent routing	PARTIAL	Hybrid	Gateway/Processor	Routing logic; Processor selection	AI agents can be manipulated to route payments maliciously
GP-006	Agent Hijacking for Token Abuse	AI assistant credential theft; Stored token abuse	PARTIAL	Hybrid	Gateway/Processor	Token access control; Authorization	Agent hijacking enables abuse of stored payment credentials
GP-007	AI Agent Velocity Evasion	Rapid agent shopping; High-velocity transaction bursts	PARTIAL	Hybrid	Gateway/Processor	Velocity rules; Rate limiting	AI agents operate at speeds that break traditional velocity controls

Total final attack families: 7

Table 2 – ATTACK × OBSERVABLE SIGNAL

Attack Family	API	Transaction	Merchant	Gateway	Processor	Routing	Behavioral	Network	Temporal	State
GP-001: API Parameter Manipulation	Parameter anomalies; Injection patterns	Amount mismatches	Baseline deviations	Validation logs	N/A	N/A	Agent reasoning anomalies	Cross-merchant patterns	Rapid variation	State inconsistency
GP-002: Webhook Forgery	Signature failures; Payload anomalies	Quota-payment mismatches	Webhook config	Webhook logs	N/A	N/A	Payload inconsistencies	Campaign patterns	Unusual timing	State transition anomalies
GP-003: Card Testing	High request rates	Small amounts; High decline rate	Checkout abuse	Rate limit logs	Auth logs	N/A	Bot patterns	BIN clusters; Campaigns	High velocity	Auth state patterns
GP-004: Agentic Protocol	Protocol anomalies	Reused proofs; Multiple grants	Agentic merchants	Protocol logs	Settlement logs	Protocol state	Agent reasoning anomalies	Attack patterns	Protocol timing	State inconsistency
GP-005: Routing Manipulation	Routing anomalies	Unexpected destinations	Routing preferences	Routing logs	Selection logs	Routing decisions	Agent manipulation	Routing patterns	Unusual timing	Routing state
GP-006: Token Abuse	Token access anomalies	Unauthorized token use	Token integration	Token logs	Auth logs	N/A	Agent hijacking	Hijacking patterns	Access timing	Token state
GP-007: Velocity Evasion	Superhuman rates	Rapid sequences	Velocity baselines	Rate limit logs	N/A	N/A	Bot patterns	Coordinated patterns	Millisecond timing	Rate limit state

Table 3 – ATTACK × SIMULATION

Attack Family	Synthetic Gateway	Processor	Merchants	API Requests	Transactions	Sequences	Timing	Network	Type
GP-001	API with validation; AI agent workflow	N/A	Merchant baselines	Manipulated parameters	Amount mismatches	Normal → manipulation → fraud	Variable	Cross-merchant patterns	Hybrid
GP-002	Webhook receiver; LLM gateway	N/A	Webhook configs	Forged webhooks	Quota credits	Forgery → credit → consumption	Variable	Campaign patterns	Algorithmic
GP-003	Checkout API with velocity rules	Auth processing	Transaction baselines	Card testing requests	Small authorizations	Testing sequences	High-velocity	BIN clusters; Campaigns	Algorithmic
GP-004	x402/AP2 protocol endpoint	Settlement processing	Agentic merchants	Protocol messages	Payment proofs; Grants	Protocol interactions	Protocol timing	Attack patterns	Agentic
GP-005	Routing engine	Processor selection	Routing preferences	Routing requests	Routing records	Normal → manipulated → fraud	Variable	Routing patterns	Hybrid
GP-006	Tokenization service	Auth processing	Token profiles	Token usage requests	Token transactions	Normal → hijacking → fraud	Variable	Hijacking patterns	Hybrid
GP-007	Gateway with velocity controls	N/A	Velocity baselines	High-velocity requests	Rapid sequences	Velocity bursts	Millisecond	Coordinated patterns	Hybrid

Table 4 – TAXONOMY DECISIONS

Candidate	Decision	Reason
GP-001: API Parameter Manipulation	KEEP	GenAI-enabled prompt injection creates qualitatively new attack vector
GP-002: Webhook/Callback Forgery	KEEP	CVE-2026-41432 demonstrates LLM gateway vulnerability
GP-003: Card Testing	KEEP	AI-powered platforms enable industrial-scale validation
GP-004: ISO 8583 Manipulation	DROP	No GenAI evidence; traditional FASTCash malware
GP-005: Agentic Protocol Replay	MERGE → GP-004	Variant of agentic protocol exploitation
GP-006: Payment Amount Manipulation	MERGE → GP-001	Variant of API parameter manipulation
GP-007: AI Agent Routing Manipulation	KEEP	Distinct – AI agent routing manipulation
GP-008: Agent Hijacking for Token Abuse	KEEP	Distinct – agent hijacking for stored credentials
GP-009: API Key Theft	MOVE → Authentication	Credential theft is Authentication-stage
GP-010: AI Agent Velocity Evasion	KEEP	Distinct – AI speed breaks velocity controls
GP-011: Configuration Manipulation	DROP	Insufficient evidence
GP-012: Agentic Protocol Exploitation	KEEP	PASS HARD test; new attack surface

Final Metrics

Metric	Value
Total final attack families	7
Total variants	18+
Important candidates merged	GP-005 → GP-004; GP-006 → GP-001
Important candidates moved	GP-009 (API Key Theft) → Authentication
Important candidates dropped	GP-004 (ISO 8583 Manipulation); GP-011 (Configuration Manipulation)
Theoretical/future threats	Failover abuse; Advanced configuration manipulation
Remaining research gaps	Real-world frequency of agentic protocol exploitation; Specific detection evasion effectiveness against production gateway ML models; Impact of emerging agentic payment protocols on fraud detection
Gateway/Processor control surfaces covered	API validation; Webhook processing; Rate limiting; Velocity rules; Routing logic; Tokenization; Protocol processing; Agent decision-making
Important Gateway/Processor surfaces not represented as separate families	ISO 8583 manipulation (dropped – no GenAI evidence); Configuration manipulation (dropped – insufficient evidence); Gateway compromise (dropped – no GenAI evidence); Processor compromise (dropped – no GenAI evidence)

Unifying Theme

The unifying theme across all 7 Gateway/Processor families is the shift from **manual/scripted API abuse** to **autonomous, adaptive, AI-agent-driven attacks**. GenAI transforms gateway/processor fraud in two fundamental ways:

1. **Prompt injection and agent hijacking** create qualitatively new attack vectors where attackers manipulate AI reasoning, not just API parameters or system configuration.
2. **AI agent speed and scale** break traditional fraud controls designed for human transaction speeds, enabling industrial-scale fraud that was previously impossible.

Traditional attacks like ISO 8583 manipulation and configuration abuse remain important but do **not** belong in a GenAI-powered taxonomy – they are traditional malware and insider attacks that exist independently of GenAI. The Gateway/Processor taxonomy must focus on where GenAI creates **new** attack surfaces or qualitatively **transforms** existing ones.